

ResolvX

Risk Management Policy

Topic-Specific Policy - Risk Governance (Governs the Risk Assessment Methodology)

POL-014 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-014
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 Clause 6.1.2, 6.1.3, 5.3 · NIST CSF 2.0 GV.RM, GV.OV · SOC 2 CC3.1–3.4

1. Purpose

This Risk Management Policy establishes risk management as a mandated, ongoing discipline at ResolvX, who is accountable for it, when a risk assessment is required, and who holds the authority to accept a given level of risk on the organisation's behalf.

The mechanics of how ResolvX identifies, scores, and treats risk using the 5×5 matrix, the FAIR quantitative model, risk appetite statements, and register fields, are already fully defined in the Risk Assessment Methodology. This policy governs how that methodology is applied across the organisation: the accountability structure, the events that trigger a fresh assessment, and the authority required to formally accept a given level of risk.

2. Scope

This policy applies to all risk identification, assessment, treatment, and acceptance activity at ResolvX, regardless of which team or system the risk originates from.

3. Relationship to the Risk Assessment Methodology

The division of responsibility between the two documents is deliberate:

- This policy (POL-014) answers: who is accountable, when must a risk be assessed, and who can accept it.
- The Risk Assessment Methodology answers: how a risk is scored, what the risk matrix and FAIR model produce, and what the register captures.

Where the two would ever appear to conflict, the Risk Assessment Methodology governs scoring mechanics, and this policy governs governance and authority. So neither document overrides the other on the topic it owns.

4. Risk Identification Triggers

A formal risk assessment is required whenever any of the following occurs:

Trigger	Assessment Required Within
New vendor onboarding above Tier 3 (per POL-005 TPRM tiering)	Before contract signature
New Critical or High tier asset added to the register (per POL-011)	30 days of onboarding
High-blast-radius production change (per POL-013 §3)	Considered as part of the change's approval, not a separate cycle
Post-incident, for any system involved in a P1 or P2 incident	10 business days after incident closure
New or changed regulatory requirement applicable to ResolvX	30 days of the requirement taking effect
No trigger event in the prior quarter for a given risk category	Full quarterly register review still applies regardless

5. Risk Acceptance Authority

The Risk Assessment Methodology defines tolerance by risk level; this policy assigns who authorised to formally accept a risk at that level. A risk is not considered accepted until the appropriate authority has signed off and an unaddressed risk sitting in the register is not the same as an accepted one.

Risk Level	Acceptance Authority	Notes
Critical (20 - 25)	CEO, with CISO concurrence	Zero-tolerance per the Methodology. Acceptance is exceptional and time-limited, not a default outcome.
High (12 - 19)	CISO	Documented rationale required in the risk register.
Moderate (7 - 11)	GRC Lead, in consultation with the relevant control owner	—
Low / Very Low (1 - 6)	Control owner	Reviewed by GRC Lead at the next quarterly register review, not individually approved in advance.

6. Independence of Assessment

A control owner may propose the initial risk scoring for a risk within their own domain, but GRC Lead reviews and confirms every High and Critical scoring before it is finalised in the register. A control owner does not both score and accept a High or Critical risk in their own domain without that independent check, here the same separation-of-duties principle applied to access control (POL-003) applies here to risk self-assessment.

7. Reporting

- GRC Lead reports the full risk register to the CISO quarterly, aligned with the Methodology's quarterly review cycle.
- Any risk scoring Critical is escalated to the CEO and CISO within 24 hours of identification, ahead of the standard quarterly cycle.
- An annual risk summary, including risk appetite review, is presented to company leadership as part of the annual policy and methodology review.

8. Roles & Responsibilities

8.1 GRC Lead

- Owns this policy and administers the risk register and methodology.
- Confirms independent scoring for High/Critical risks (§6) and tracks acceptance sign-off (§5).
- Ensures risk assessments occur against the triggers in §4.

8.2 CISO

- Accepts High risks and concurs on Critical risk acceptance.
- Receives quarterly and Critical-risk escalation reporting.

8.3 CEO

- Holds final acceptance authority for Critical risks.
- Reviews risk appetite annually alongside the Methodology's own review cycle.

8.4 Control Owners

- Propose initial risk scoring within their domain and accept Low/Very Low risks.
- Execute treatment actions assigned to them and report status to GRC Lead.

9. Compliance and Enforcement

A risk that should have triggered an assessment under §4 but did not, or a risk treated as accepted without sign-off from the authority defined in §5, is treated as a control deficiency and logged in the Corrective Action Plan.

10. Document Control

Policy ID	POL-014
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	GRC Lead
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 Clause 6.1.2, 6.1.3, 5.3 · NIST CSF 2.0 GV.RM, GV.OV · SOC 2 TSC CC3.1–3.4
Related Documents	POL-001 (Information Security Policy), POL-003 (Access Control Policy), POL-005 (Vendor Management Policy), POL-011 (Asset Management Policy), POL-013 (Change Management Policy), Risk Assessment Methodology

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		